T

TPOS

THE OPERATING SYSTEM FOR TRAILER DEALERS

Product Specification

A business-level, implementation-agnostic specification — sufficient for an independent team to rebuild the system from scratch in the stack and architecture of their choosing.

Document v2.0 · Requirements specification (technology-neutral) · B&W wireframes · Appendices A–F · Companions: Proposal & Bid/Delivery Pack · Confidential draft

Executive Overview

TPOS is a multi-tenant vertical SaaS that runs an independent trailer dealership's entire operation — its **public storefront** and its whole **back office** — on one shared record of truth, where a single trailer is seen through **12 role lenses** (inventory → deal → work order → invoice → title → delivery → listing). Sold **hosted** (monthly), **licensed** (annual), or **self-hosted** (one-time).

The product

- **Who:** small-to-mid used/refurbished commercial-trailer dealers, replacing a website builder + CRM + spreadsheets + accounting + listing sites with one role-aware platform.
- **Core loop:** acquire → recondition → price → list → lead → quote → finance → title → deliver → book — each stage hands the *same* record to the next role.
- **Pricing:** Hosted $199–$1,290/mo · annual license · one-time self-host.

Key qualities (§12)

- **Strict tenant isolation** — no path crosses tenants.
- **Real-time** — others' changes appear without refresh or polling delay.
- **Responsive** — good UX from phone to ultra-wide desktop.
- **Auditable** by default; **deploys hosted or self-host** from one product.

A requirements specification

This document states **what** the system must do and the qualities it must have, and is deliberately **technology-neutral**. It is one of three:

① **Product Specification**	this document — requirements only
② Functional Spec. Proposal	a proposed technical solution per requirement (architecture, frontend, integrations)
③ Bid & Delivery Pack	scope cutline, integration register, RACI, estimate, delivery stages

Reading guide

Product & requirements	§1–14
Data dictionary	Appendix A
Security & compliance	Appendix B
Onboarding · formulas	Appendix C · D
Notifications · accounting	Appendix E · F

Technology-neutral by design: this specification prescribes no stack. Proposed technologies, architecture and the rationale live in the separate **Functional Specification Proposal**; scope, estimate and delivery plan live in the **Bid & Delivery Pack**. The build team owns all implementation choices.

Contents

Executive Overview

2. Product Vision & Business Model
3. Multi-Tenancy & Deployment Modes
4. Personas & Roles
5. Domain Model — One Record, Many Lenses
6. The Trailer Lifecycle
7. Functional Specification by Role
8. Public Storefront
9. Cross-Cutting Capabilities
10. Reporting & KPIs
11. Roles & Permissions Matrix
12. External Integrations
13. Non-Functional Requirements
14. Acceptance Criteria
15. Glossary
16. Appendix A — Data Dictionary & Relational Schema
17. Appendix B — Security, Privacy & Compliance
18. Appendix C — Onboarding & Data Import
19. Appendix D — Derived-Field Formulas
20. Appendix E — Notification & Document Catalog
21. Appendix F — Accounting Export (QuickBooks & Beyond)

1 · Product Vision & Business Model

TPOS is a vertical SaaS that gives an independent trailer dealership one system to run both its **public storefront** and its entire **back office** — acquisition, reconditioning, pricing, marketing, sales, financing, titling, delivery and bookkeeping — on a single shared record of truth.

The market is fragmented small-to-mid dealers (used & refurbished commercial trailers: dry vans, flatbeds, reefers, lowboys, dumps, tankers, chassis) who today stitch together a website builder, a generic CRM, spreadsheets, QuickBooks and listing sites (TruckPaper, Facebook). TPOS replaces that stack with a purpose-built, role-aware platform.

Revenue model

Offering	Pricing	For	Notes
Hosted — Starter	$199 / month	Single lot, ≤ ~25 units	Storefront + CRM + inventory; core roles
Hosted — Growth	$499 / month	Multi-lot dealers	All roles, financing, dispatch, reporting
Hosted — Enterprise	$1,290 / month	Large / multi-location	Unlimited units & seats, API, SSO, priority support
Annual License	$9,900 / year	Dealers wanting to self-host	Right to run the software on own infrastructure; updates included
One-Time Purchase	$24,000 + $3,000/yr support	Buy-to-own	Perpetual self-host license; optional support & updates

The platform operator (TPOS, Inc.) additionally runs a **super-admin control plane** to provision tenants, meter usage, bill subscriptions, and support dealers (see §6.12).

Product principles

- **One record, many lenses.** A trailer is simultaneously inventory, a deal, a work order, an invoice line, a title file, a delivery, and a public listing. Every role edits the *same* entity through a view shaped to its job — never a copy.
- **The storefront is generated, not separate.** Inventory marked *available* is automatically published to the dealer's branded public site and syndicated to listing channels.
- **Role-first, not module-first.** Each user lands on a workspace built around their daily goals and decisions, not a generic menu of tables.

- **Auditable by default.** Price changes, discounts, status transitions and money movement are logged with who/when/why.

2 · Multi-Tenancy & Deployment Modes

Each dealership is a **tenant** with isolated data, its own users, branding, lots, inventory and storefront domain. The system must support three deployment modes from one codebase:

Mode	Hosting	Tenancy	Billing
Hosted (SaaS)	Operator-run cloud	Many tenants per deployment (logical isolation, per-tenant scoping on every query)	Recurring subscription, usage-metered
Licensed self-host	Dealer infrastructure	Typically single tenant; multi-tenant allowed	Annual license key, update channel
One-time self-host	Dealer infrastructure	Single tenant	Perpetual key; optional support plan

Requirement. Tenant isolation must be enforced at the data layer (no cross-tenant read/write possible), branding/config is per-tenant, and a tenant's storefront resolves on a custom domain or subdomain. The control plane (§6.12) exists only in hosted mode.

3 · Personas & Roles

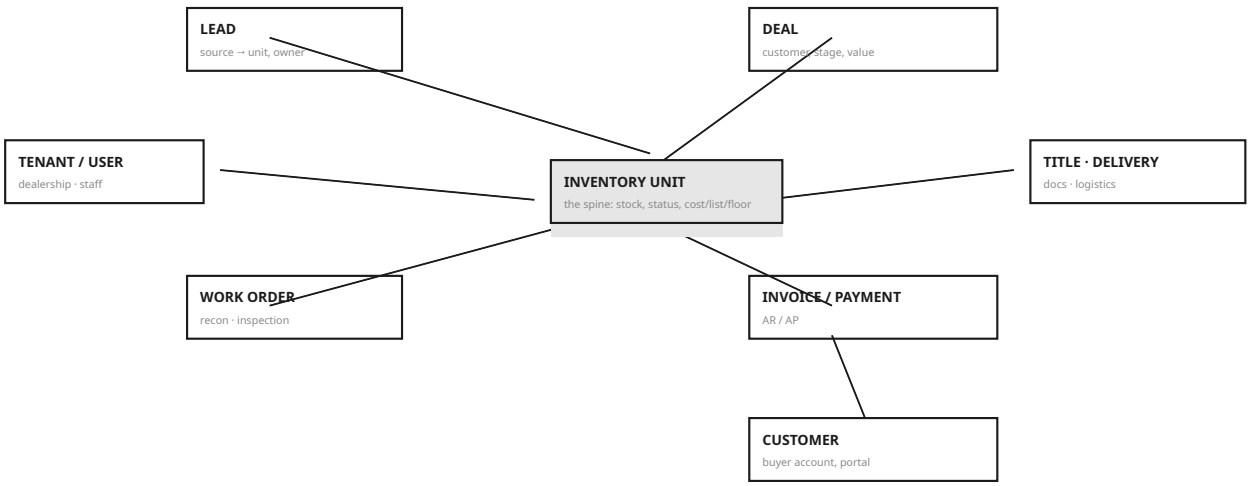
TPOS serves twelve roles across the dealership, plus the dealership's own customers and the platform operator. Each persona has a primary goal and a small set of "jobs to be done" that the system must make fast.

Role	Primary goal	Key jobs-to-be-done
Owner / Dealer Principal	Run a healthy, profitable business	See revenue, gross, turn & pipeline at a glance; spot aged inventory, overdue AR, stalled deals; manage the team
Lead Generation / BDC	Capture & route every inquiry fast	Triage the lead inbox, measure response time & sources, run campaigns, assign to sales
Salesperson	Work the pipeline & close	Advance deals through stages, build quotes, track follow-ups, manage customers
Sales Manager	Coach, forecast, approve	Compare rep performance, forecast the month, approve below-floor discounts
Pricing Analyst	Maximize margin & turn	Reprice against age & demand, monitor margin, compare market comps, approve changes

Inventory Manager	Source, recon, place & turn units	Track stock by status & location, manage intake & aging, push units into recon & to the lot
Service Technician	Recon & inspect units quickly	Work the work-order board, complete inspection checklists, log hours & parts
Office / Titles & Admin	Keep paperwork clean & legal	Track titles/DMV, collect deal documents, schedule signings & deliveries
Bookkeeper / Accounting	AR/AP, cash, month-end	Issue & collect invoices, record payments, pay bills, close the month, report P&L
Delivery Dispatch	Move units to buyers	Schedule deliveries, assign drivers/carriers, quote freight, track in-transit
Customer (buyer)	Buy with confidence, self-serve	View quotes, apply for financing, track delivery, sign & download documents
Platform Super-Admin	Operate the SaaS business	Provision & bill tenants, watch MRR/churn, monitor usage & system health, support dealers

4 · Domain Model — One Record, Many Lenses

The data model is small and tightly linked. The **Trailer (Inventory Unit)** is the spine; everything references it.



Entity-relationship overview. One trailer threads through inventory, deals, work orders, invoices, title and delivery; each role reads the same graph.

Core entities

Entity	Purpose	Key attributes
Tenant	A dealership	name, plan, branding, lots[], storefront domain, billing
User	A staff member	name, role(s), permissions, lot scope
Inventory Unit (Trailer)	The spine	stock #, type, year, make, length, axles, capacity, condition, photos, **cost**, **list**, **floor**, status, location, acquired/sold dates, views, lead-count
Lead	An inbound prospect	name, company, source, interest→Unit, status, owner→User, value, created
Customer	A buyer account	name, company, contacts, deals[], documents[]
Deal	A sales opportunity	customer, unit, stage, value, probability, salesperson, financing
Quote	A priced offer	unit, line items (price, prep, freight, tax), total, validity
Work Order	Recon / inspection / repair	unit, type, status, technician, tasks[], parts cost, hours est/actual

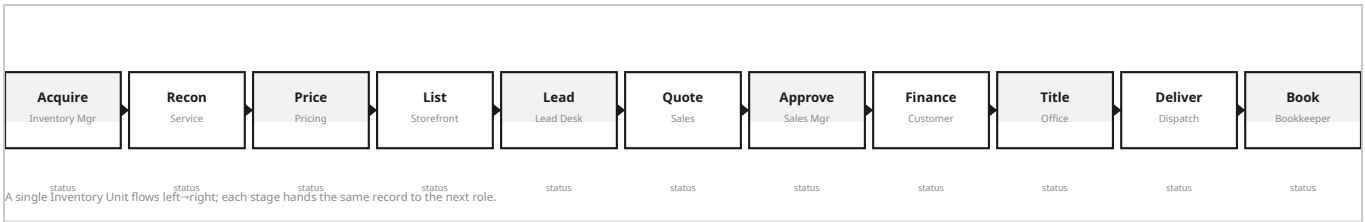
Invoice / Payment	Money in & out (AR/AP)	customer/vendor, unit, amount, status, dates, method
Title / Document	Legal & DMV paperwork	unit, title status, state, lien, document checklist & signatures
Delivery	Logistics of handoff	unit, deal, origin, destination, driver/carrier, status, ETA, freight cost

The status machine

An Inventory Unit moves through: `incoming → recon → available → pending → sold`. Status is the single field that re-shapes the unit across roles — e.g. *available* publishes it to the storefront; *pending* hides it from new leads; *sold* moves it to delivery & books revenue. The system must guard valid transitions and log each one.

5 · The Trailer Lifecycle

The end-to-end flow ties every role together. Each stage hands the same unit to the next role.



Trailer lifecycle — the same unit handed role to role from acquisition through booking the sale.

6 · Functional Specification by Role

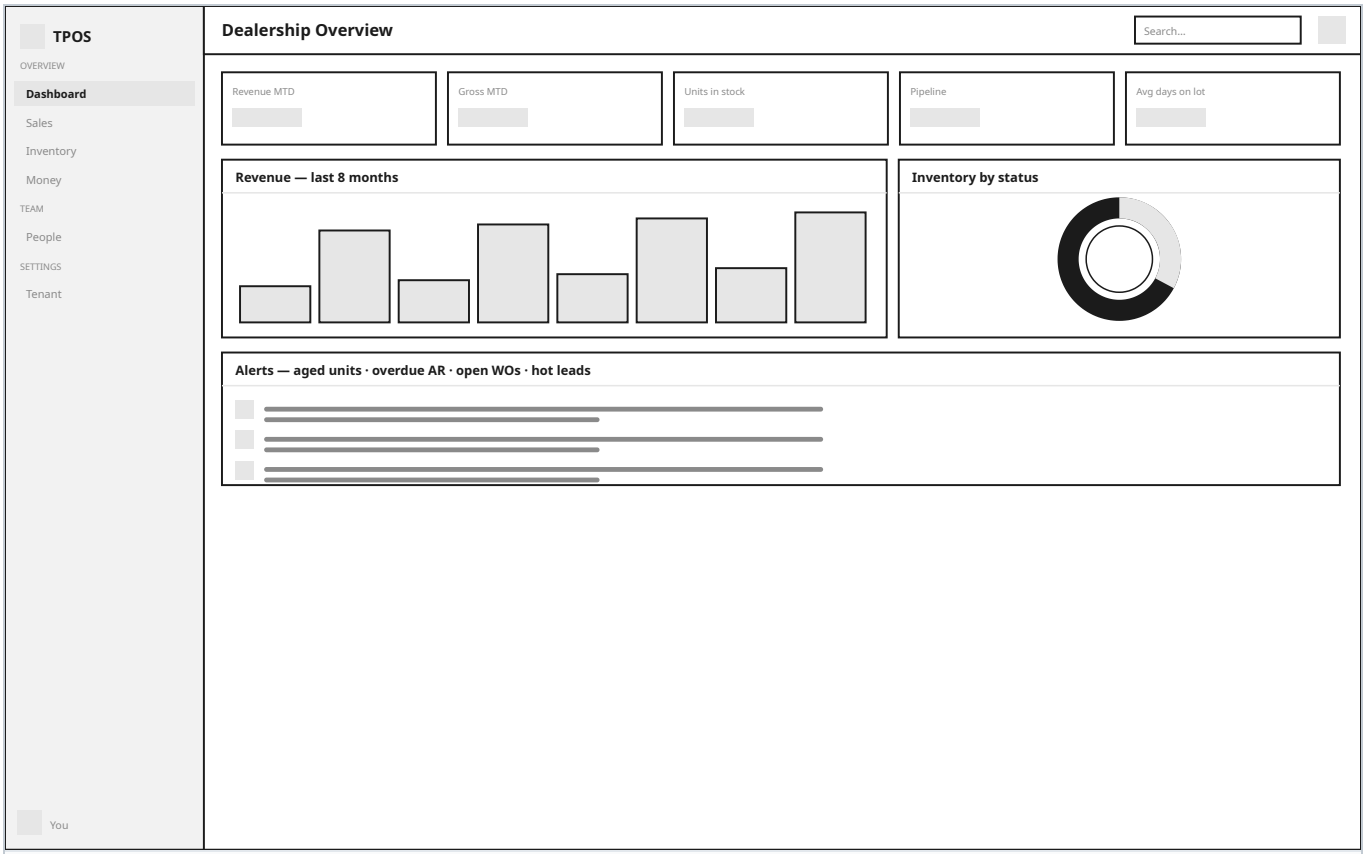
Each role below states its **goal**, the **screens** it owns, its **functional requirements** (what the system must let it do), and a **wireframe** of the primary workspace. Wireframes define information architecture and layout only — visual design, components and stack are the build team's choice.

6.1 Owner / Dealer Principal

Goal. Run a healthy, profitable business at a glance.

Functional requirements

- Executive dashboard: revenue, gross, units, pipeline, days-on-lot.
- Cross-role alert feed: aged inventory, overdue AR, open work orders, hot/new leads.
- Drill into Sales and Inventory; manage team & tenant settings & billing.



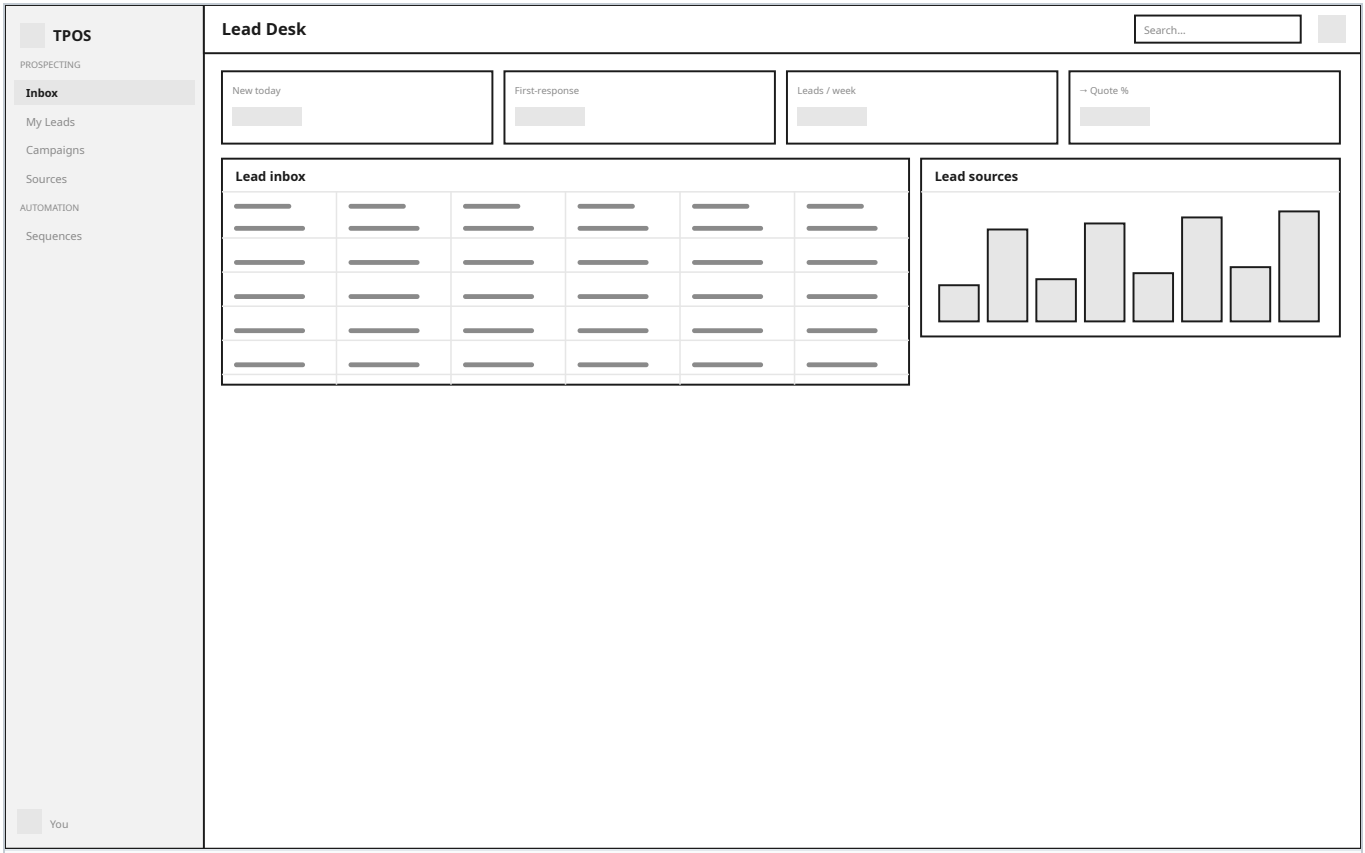
Wireframe — Owner / Dealer Principal primary workspace (layout & IA only).

6.2 Lead Generation / BDC

Goal. Capture every inquiry and route it fast.

Functional requirements

- Unified lead inbox (web, listing sites, phone, walk-in) with age & first-response timers.
- Assign/route leads to salespeople; one-click call/email.
- Source & campaign analytics: volume, cost-per-lead, conversion to quote.



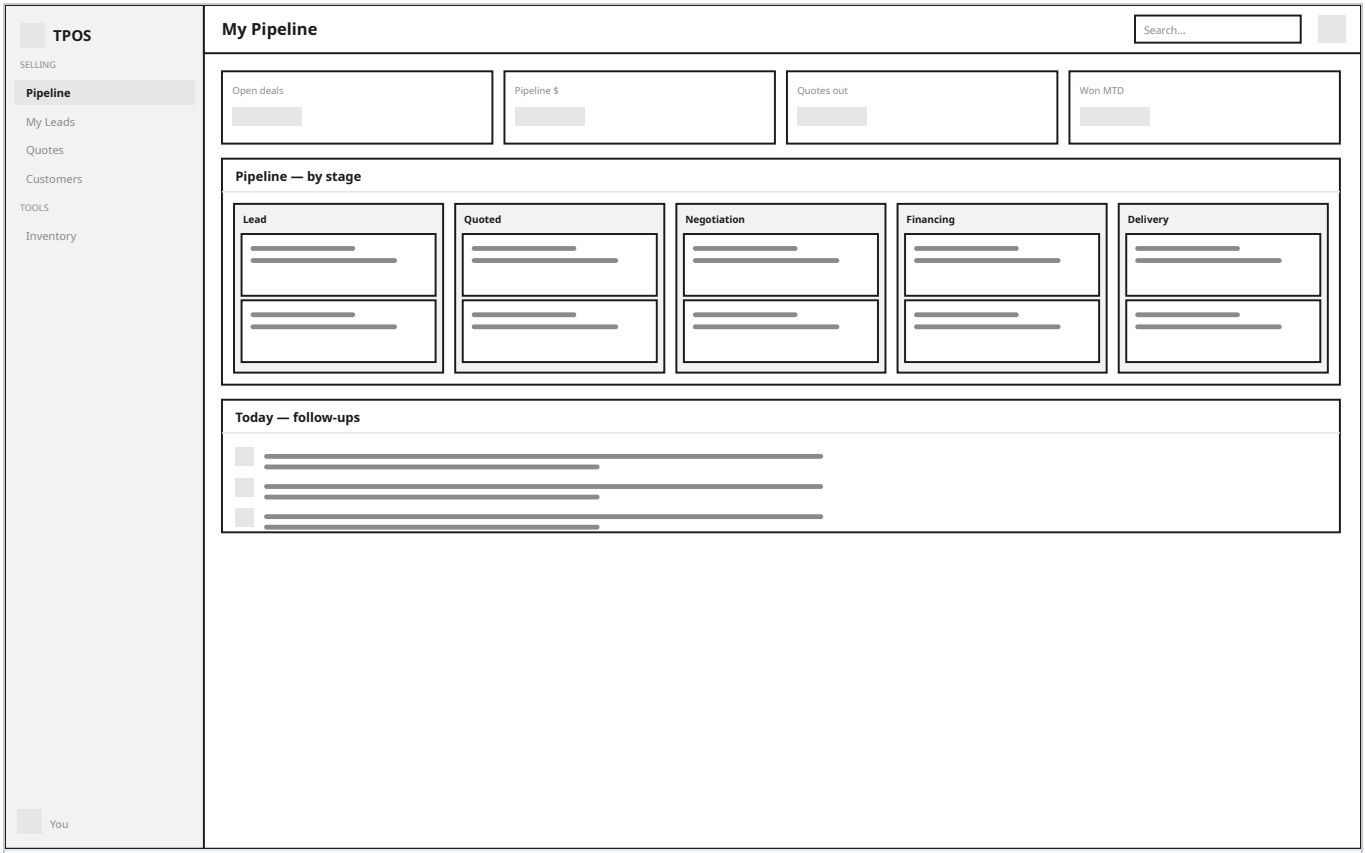
Wireframe — Lead Generation / BDC primary workspace (layout & IA only).

6.3 Salesperson

Goal. Work the pipeline and close deals.

Functional requirements

- Kanban pipeline of own deals across stages with probability & last-touch.
- Quote builder tied to a unit (price, prep, freight, tax → total).
- Daily follow-up tasks; customer accounts and history.



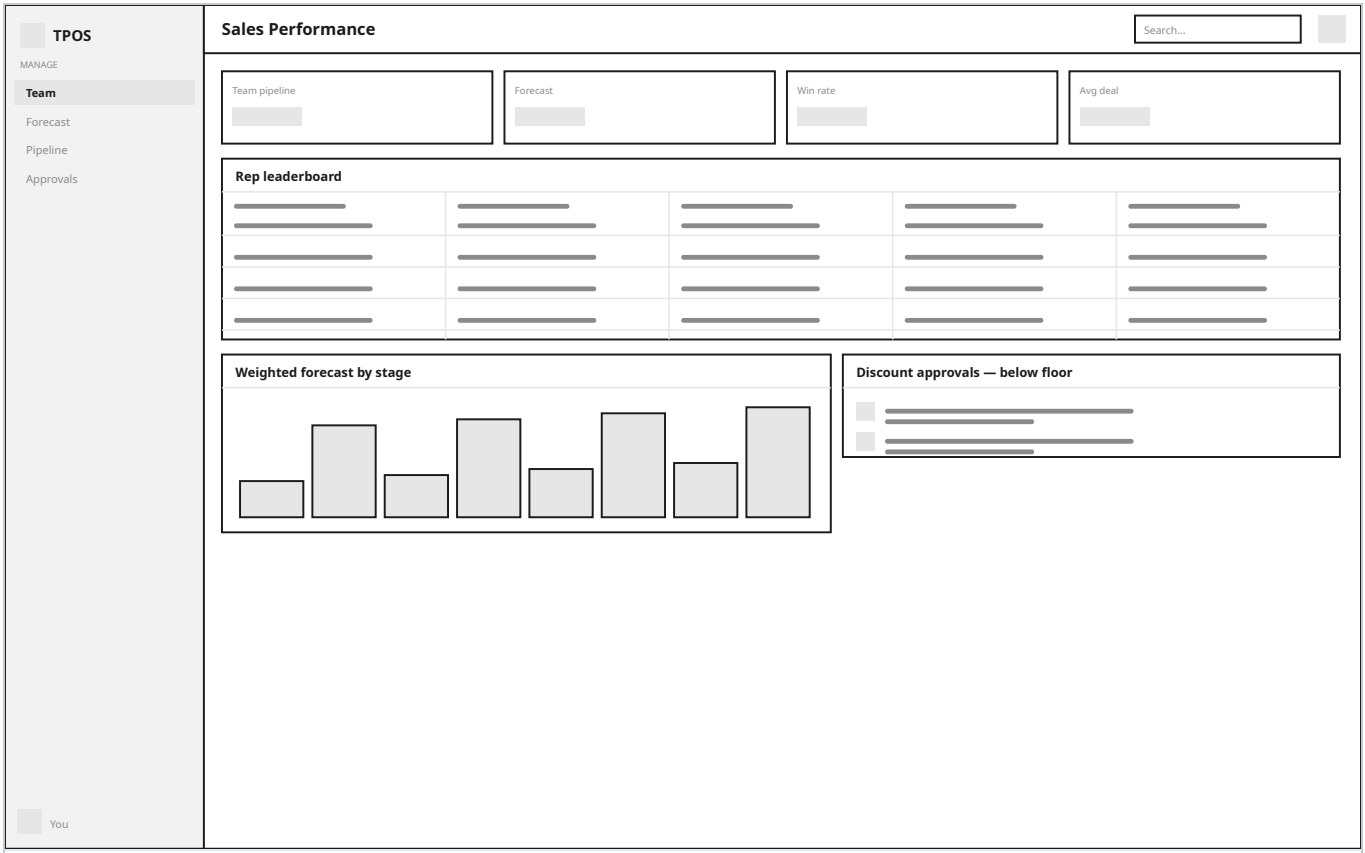
Wireframe — Salesperson primary workspace (layout & IA only).

6.4 Sales Manager

Goal. Coach the team, forecast, approve.

Functional requirements

- Rep leaderboard (deals, pipeline, won, win-rate) and conversion funnel.
- Weighted forecast by stage.
- Approve/deny/counter below-floor discounts — logged with reason.



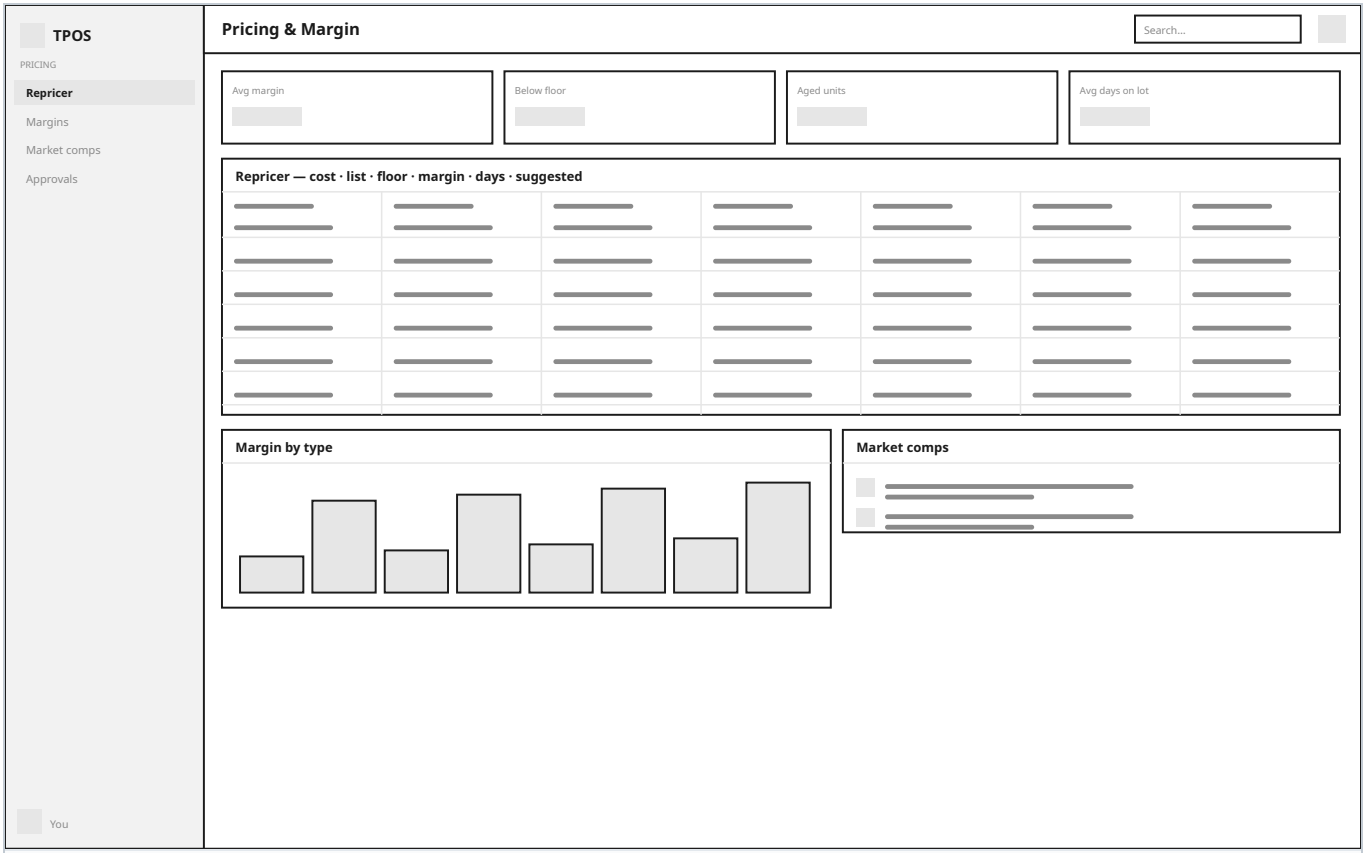
Wireframe — Sales Manager primary workspace (layout & IA only).

6.5 Pricing Analyst

Goal. Maximize margin and turn.

Functional requirements

- Repricer over available units: cost/list/floor/margin/days/demand with a suggested price & reason.
- Margin monitoring by type; aged-unit reprice prompts.
- Market comparables; price-change approval queue.



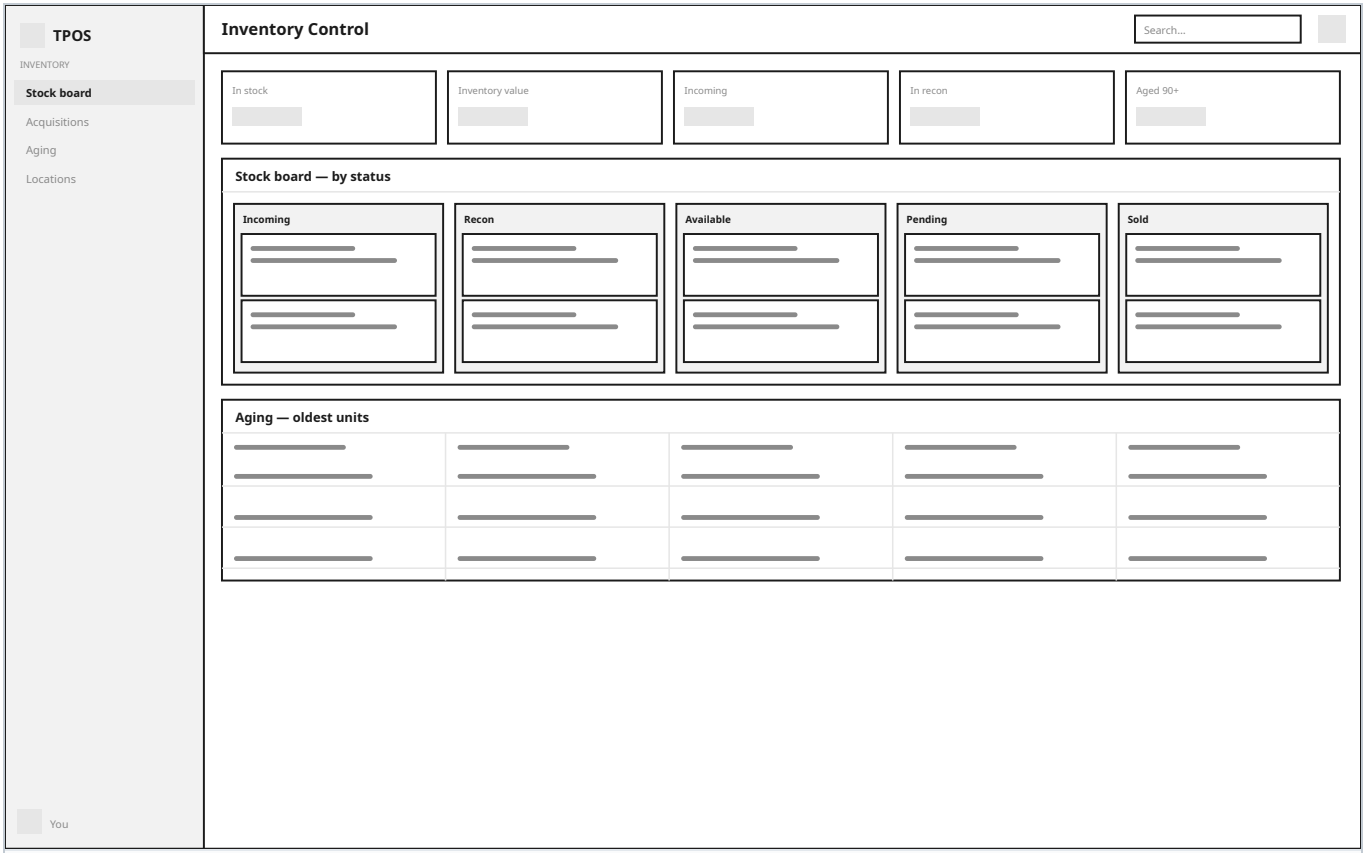
Wireframe — Pricing Analyst primary workspace (layout & IA only).

6.6 Inventory Manager

Goal. Source, recon, place and turn units.

Functional requirements

- Stock board by status (incoming→recon→available→pending→sold) and by location/lot.
- Acquisition intake with ETA & cost; push units into recon and onto the lot.
- Aging report and turn metrics; trigger reprice/clearance.



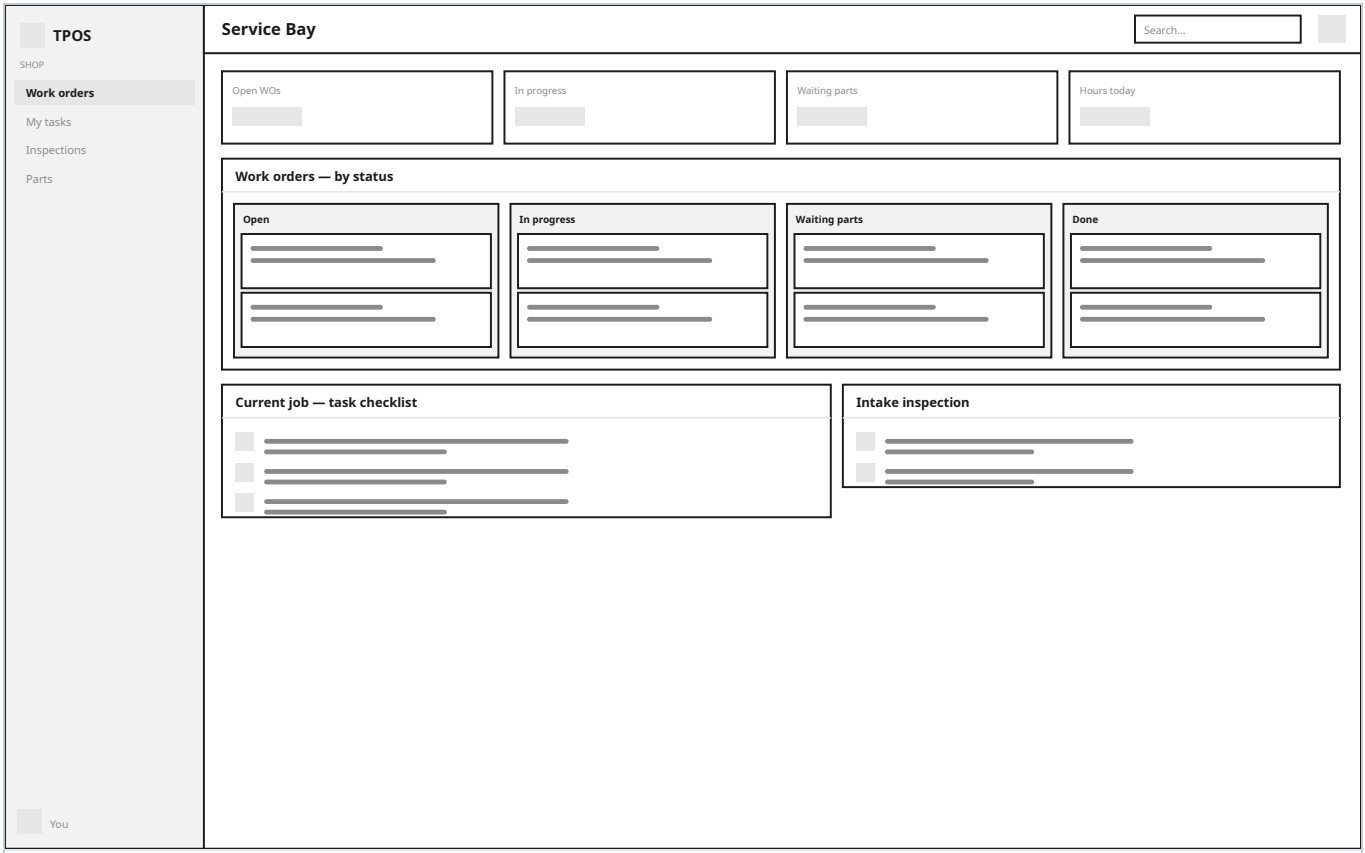
Wireframe — Inventory Manager primary workspace (layout & IA only).

6.7 Service Technician

Goal. Recondition and inspect units quickly.

Functional requirements

- Work-order board by status with hours-vs-estimate and parts cost.
- Per-job task checklist; intake inspection checklists (brakes/tires/lights/floor).
- Log hours, parts and photos against the unit.



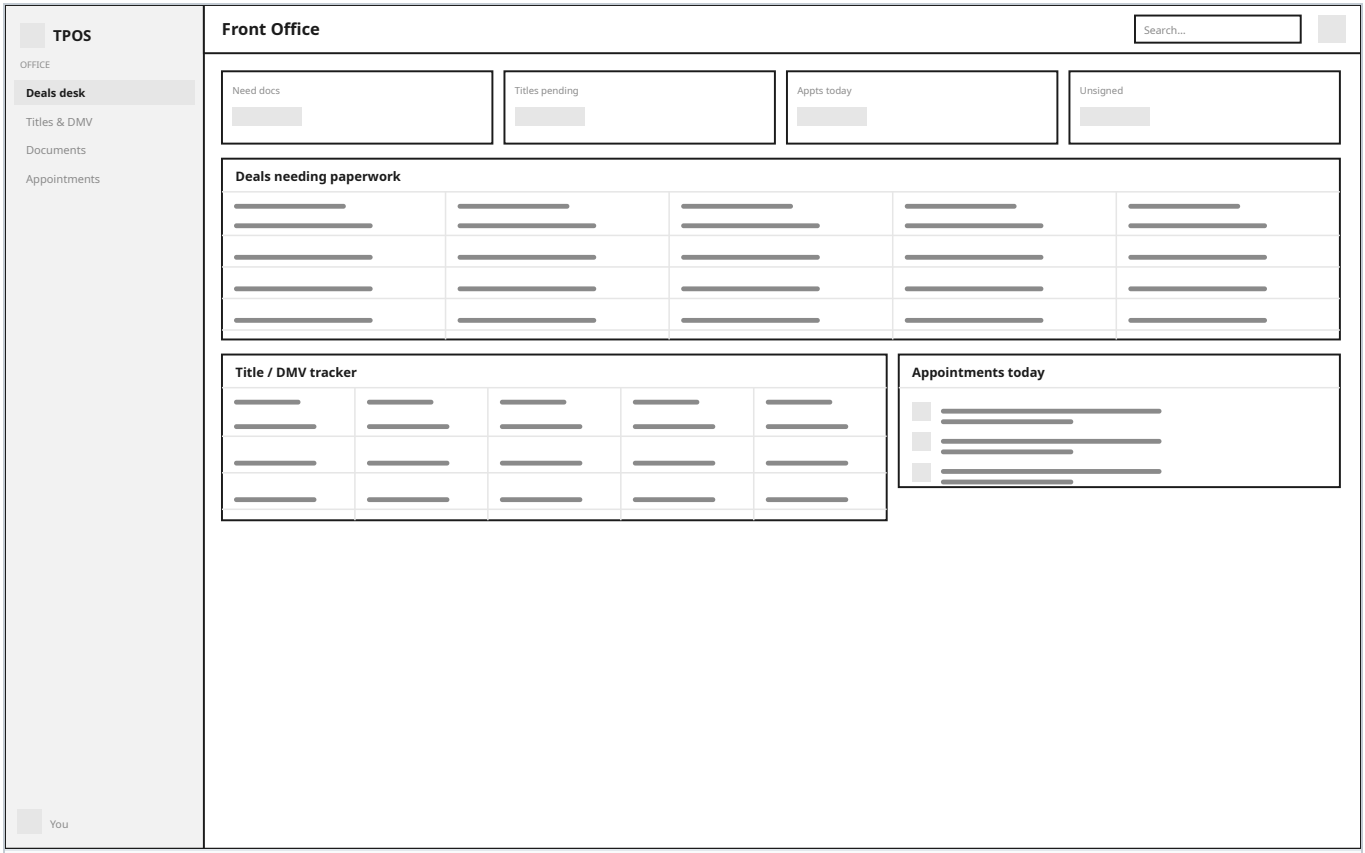
Wireframe — Service Technician primary workspace (layout & IA only).

6.8 Office / Titles & Admin

Goal. Keep paperwork clean and legal.

Functional requirements

- Deals-needing-documents queue with missing-doc flags (title, bill of sale, financing, insurance).
- Title / DMV tracker by unit (in hand / applied / pending / lien release) per state.
- Appointments & signings; document checklist & e-signature.



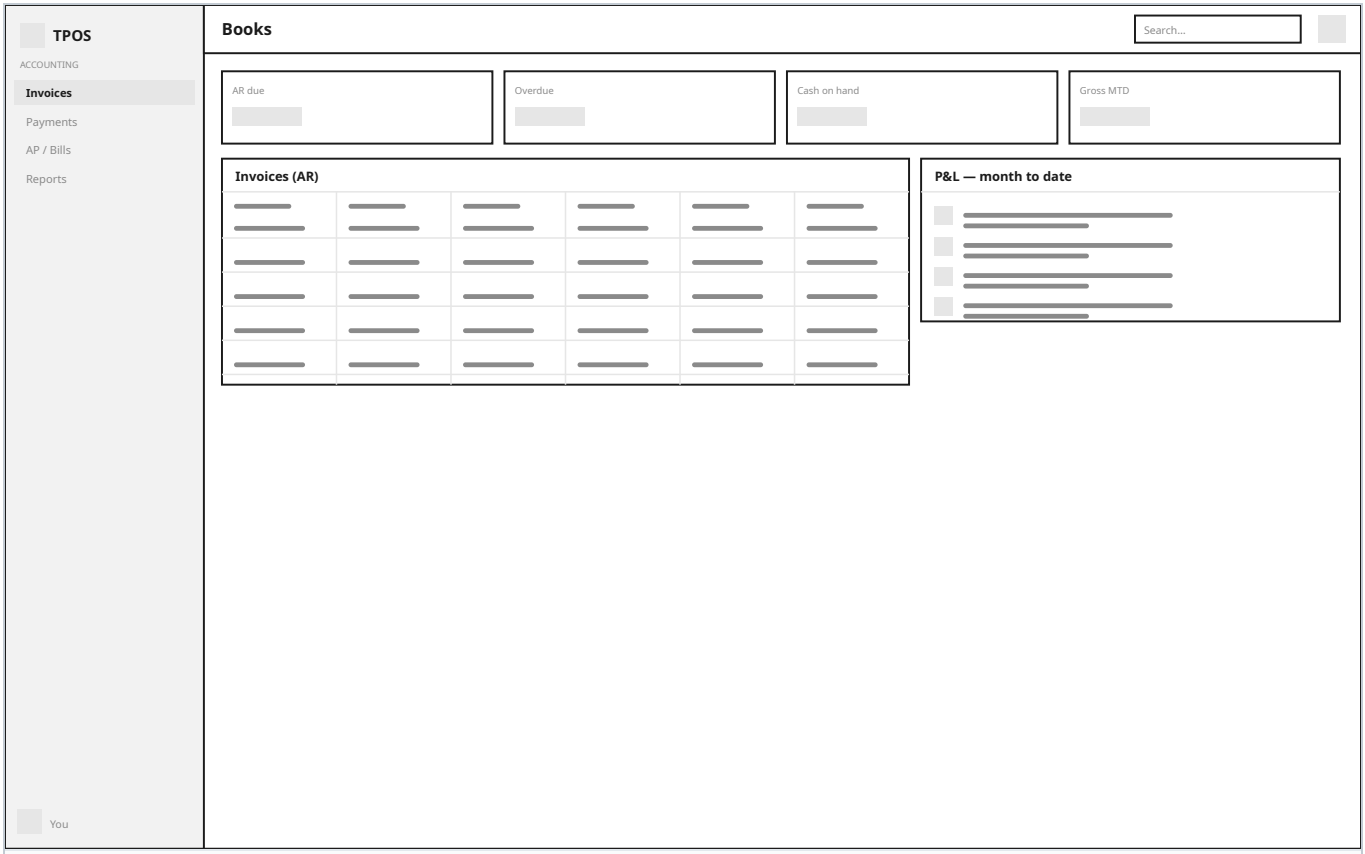
Wireframe — Office / Titles & Admin primary workspace (layout & IA only).

6.9 Bookkeeper / Accounting

Goal. AR/AP, cash and month-end.

Functional requirements

- Invoices (AR) with status (paid/due/overdue) and record-payment.
- AP / vendor bills; cash position; payments ledger.
- Month-end P&L (revenue, COGS, gross, expenses, net).
- Manual, on-demand **accounting export** — QuickBooks first, other systems later (Appendix F).



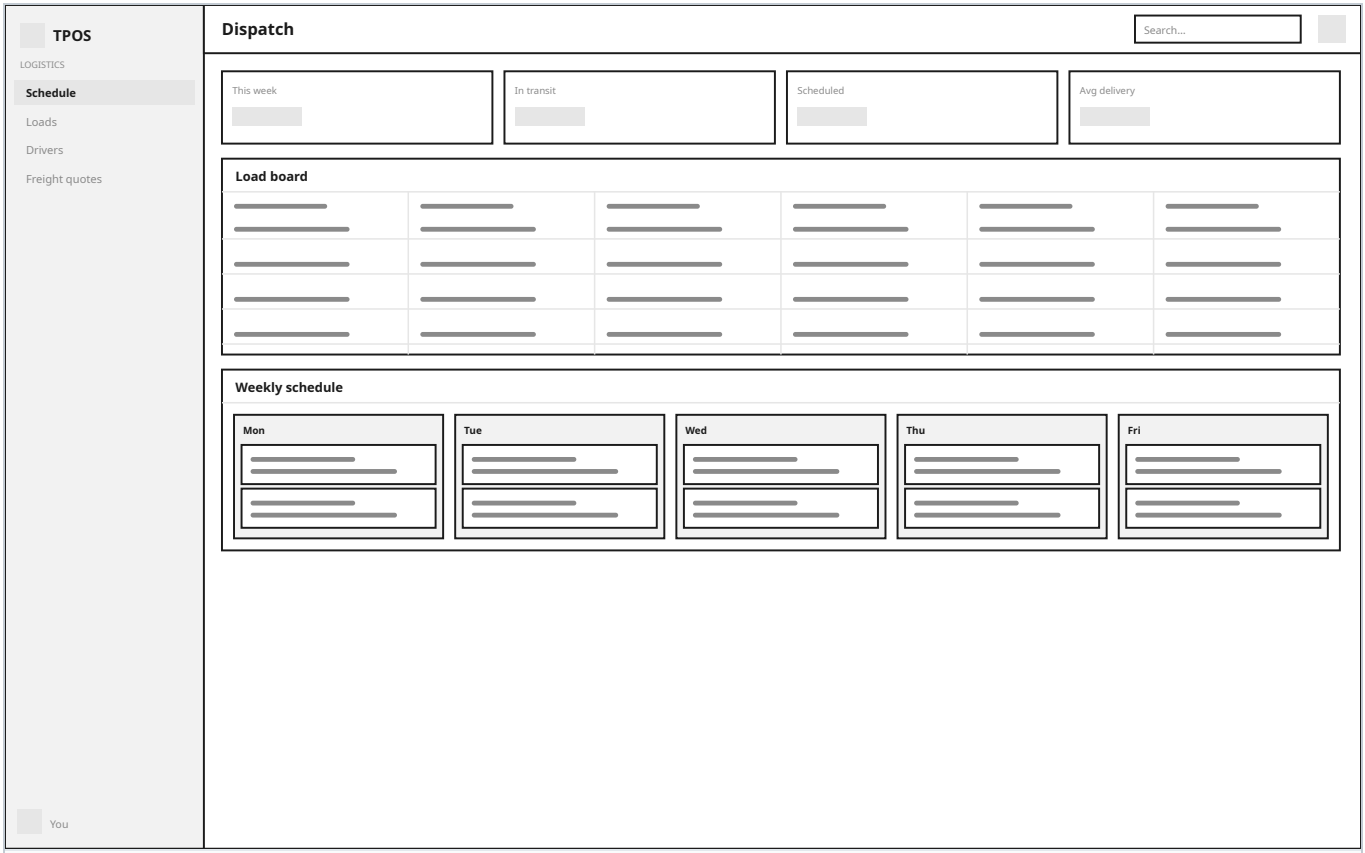
Wireframe — Bookkeeper / Accounting primary workspace (layout & IA only).

6.10 Delivery Dispatch

Goal. Move sold units to buyers.

Functional requirements

- Load board of units needing delivery with destination, carrier/driver and status.
- Weekly delivery schedule; assign drivers/carriers.
- Freight rate quotes by lane; in-transit tracking with ETA.



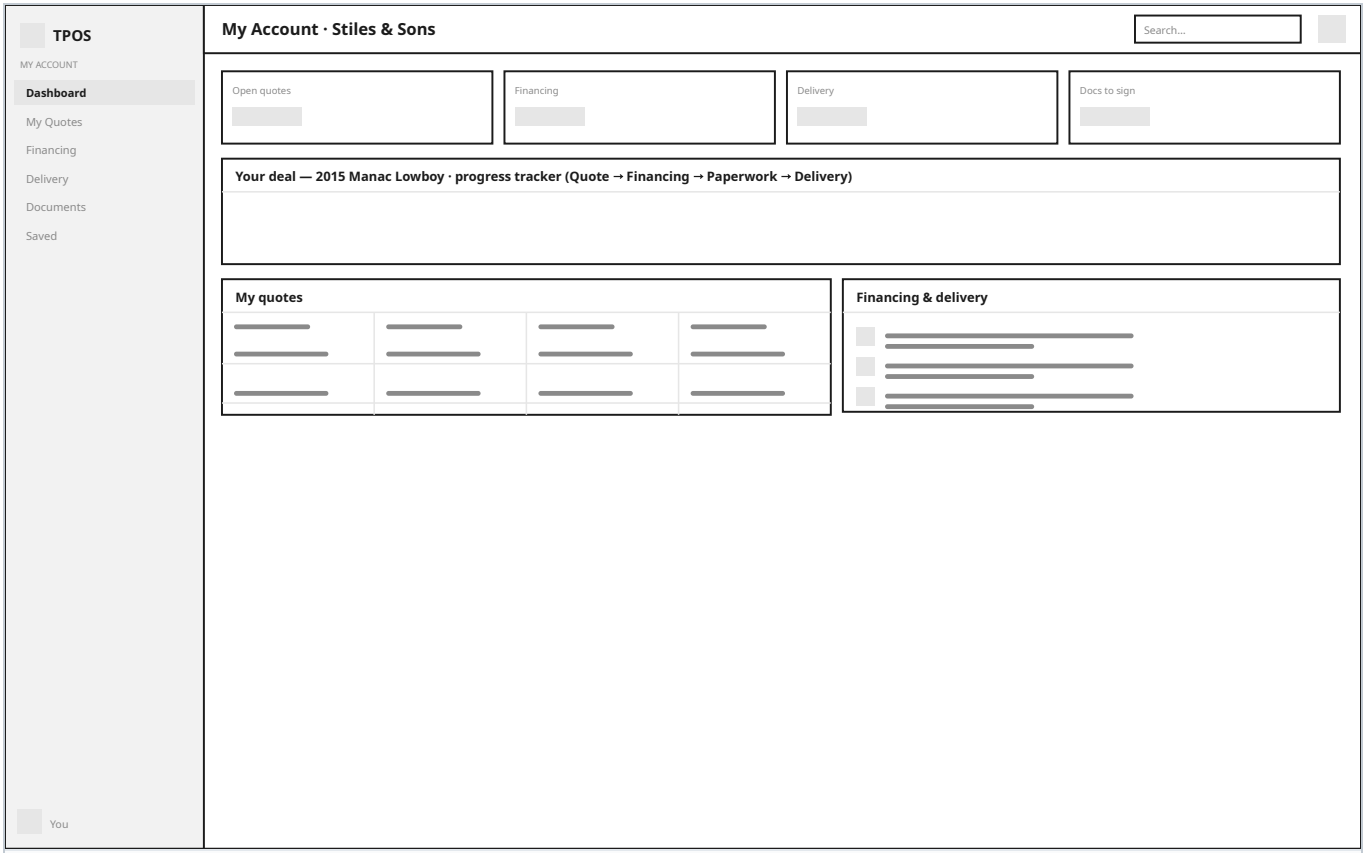
Wireframe — Delivery Dispatch primary workspace (layout & IA only).

6.11 Customer (Buyer) Portal

Goal. Buy with confidence, self-serve.

Functional requirements

- Deal progress tracker (quote → financing → paperwork → delivery).
- View/accept quotes; apply for financing and see decision status.
- Track delivery; review, e-sign and download documents; saved trailers.



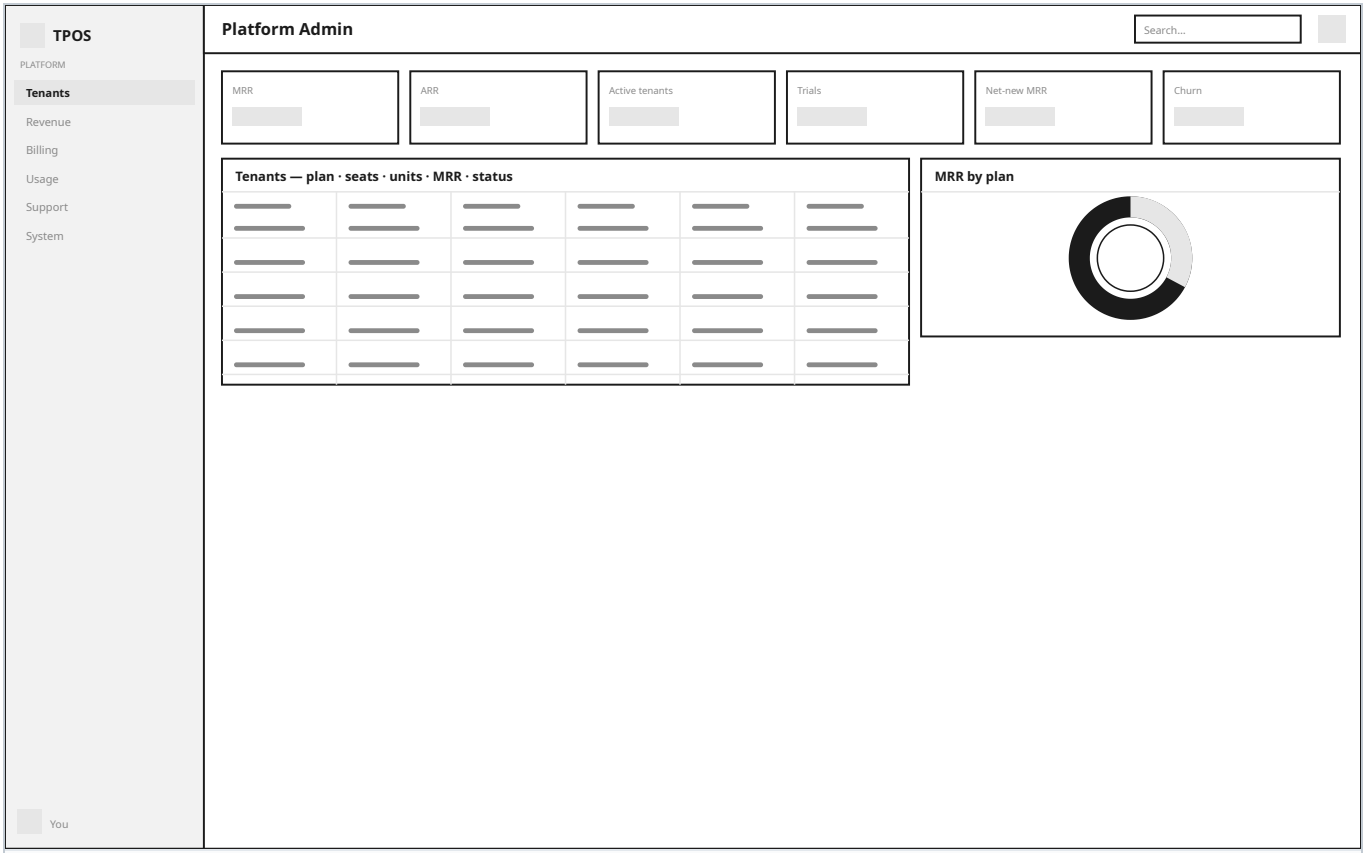
Wireframe — Customer (Buyer) Portal primary workspace (layout & IA only).

6.12 Platform Super-Admin

Goal. Operate the SaaS business (hosted mode).

Functional requirements

- Tenant directory with plan, seats, units, MRR and status; provision & manage.
- Revenue (MRR/ARR/net-new/churn), MRR-by-plan, trials & onboarding.
- Cross-tenant usage metering, support queue and system-health monitoring.



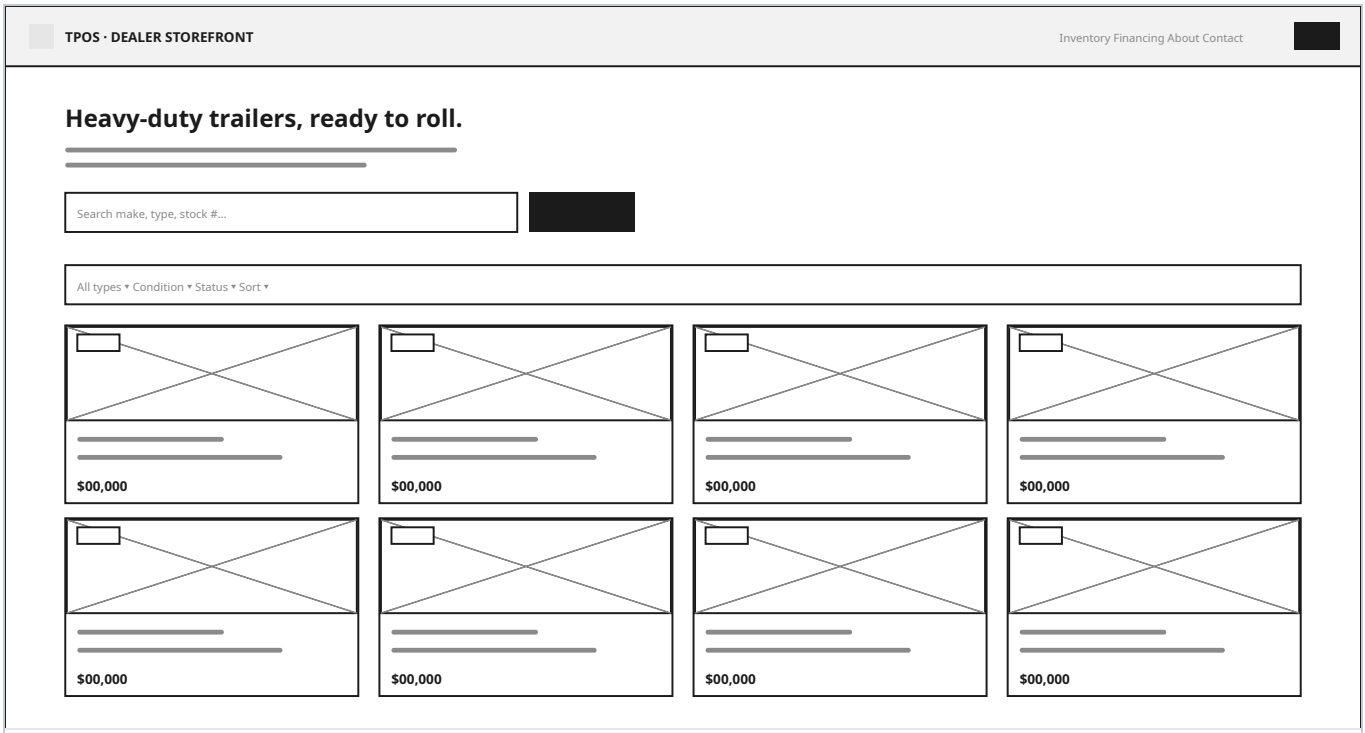
Wireframe — Platform Super-Admin primary workspace (layout & IA only).

7 · Public Storefront

Every tenant gets a branded, mobile-first public website auto-generated from its *available* inventory. It is the demand engine that feeds the Lead Desk.

Functional requirements

- Inventory grid with filter (type, condition, status), keyword search and sort (featured / price / year); each unit shows photos, key specs, price, location and a status badge.
- Deep-linkable, shareable detail pages per unit (full specs, photos, description) with status (Available / Pending / Sold).
- Lead capture: "Request a quote" and "Sell your trailer" forms create a **Lead** in the tenant's back office and notify staff; financing pre-qualification entry point.
- Informational pages (financing, about, contact) and tenant branding (logo, colors, phone, address).
- Units automatically appear/disappear as their status changes; optional syndication to external listing channels.



Public storefront — generated from available inventory; forms create leads in the back office.

8 · Cross-Cutting Capabilities

- **Global search** across units, leads, customers, deals, invoices and documents, scoped to the tenant and the user's permissions.

- **Notifications** (in-app + email/SMS) for new leads, approvals needed, overdue AR, delivery updates and title actions.
- **Activity log / audit trail** on every entity: status changes, price changes, discounts, payments, document signatures — who, when, why.
- **Comments & @mentions** on units, deals and work orders so roles hand off context.
- **Tasks & follow-ups** assignable to users, surfaced on each role's dashboard.
- **Document storage & e-signature** for titles, bills of sale, financing and delivery receipts.

9 · Reporting & KPIs

All dashboards derive from the shared record so figures reconcile across roles. Core KPIs the system must compute:

Domain	KPIs
Sales	Pipeline value, weighted forecast, win rate, average deal, units sold (period), revenue, gross profit, sales-cycle length
Inventory	Units in stock by status, inventory value & cost, average days on lot, aged units (90+), turn rate, by-location counts
Pricing	Average margin %, units below floor, margin by type, reprice impact
Marketing	Leads by source, cost per lead, first-response time, lead→quote→won conversion
Service	Open/in-progress/waiting work orders, recon cost & cycle time, hours utilization
Money	AR aging, AP due, cash position, gross margin, monthly P&L
Platform (operator)	MRR / ARR, net-new MRR, churn, trials & conversions, seats & units per tenant, usage, uptime

10 · Roles & Permissions Matrix

Access is role-based and tenant-scoped. A user may hold multiple roles (common in small dealers). Sample matrix (✓ = full, ◑ = own records, · = read-only, blank = none):

Capability	Owner	Lead	Sales	S.Mgr	Price	Inv	Svc	Office	Books	Disp	Cust
View inventory	✓	·	·	·	✓	✓	·	·	·	·	store
Edit price / floor	✓			◑	✓	·					
Work leads	·	✓	◑	✓							
Advance deals	·		◑	✓				·	·	·	own
Approve discount	✓			✓	◑						

Work orders	·					✓	✓				
Titles / documents	·		·					✓	·	·	own
Invoices / payments	·							·	✓		own
Schedule delivery	·		·			·		·		✓	·
Manage users / billing	✓										

The Platform Super-Admin operates above all tenants and is not on this per-tenant matrix.

11 · External Integrations

Integration	Purpose
Financing / lenders	Soft-pull pre-qualification, application submission, decision status into Deal & Customer portal
Listing syndication	Push available units to TruckPaper, Facebook Marketplace, Google; pull leads back
Title / DMV & e-sign	Title status, lien release, electronic signing of titles & bills of sale
Payments	Deposits, payoffs, ACH/wire/card; reconcile to invoices
Freight / carriers	Freight rate quotes, dispatch, in-transit tracking
Accounting export	Export invoices, payments & journal entries to the dealer's accounting system (QuickBooks first; others later)
Email & SMS	Lead notifications, customer comms, delivery/title updates
Platform billing	Subscription billing & metering for the SaaS operator (hosted mode)

12 · Non-Functional Requirements

Area	Requirement
Multi-tenant isolation	Strict per-tenant data isolation enforced at the data layer; no read or write path can cross tenants, even if application code has a bug. Provable by an automated cross-tenant negative test.
Real-time collaboration	Changes by one user — status, price, a new lead, an assignment, a payment — appear to others viewing the same data within ~1–2 seconds, **without a manual refresh and without perceptible polling delay**.
Concurrency & density	**Maximize the number of simultaneous active users supported per server**; the system scales horizontally and shows no per-tenant degradation as tenants and users grow.
Performance	Interactive actions feel instant; dashboards load < 2 s and lists/search respond within a few hundred ms at typical tenant volumes.
Responsive & multi-device	Good, usable UX across **phone, tablet, laptop and ultra-wide desktop**; touch and pointer input; field roles (recon, delivery) usable on a phone/tablet; the public storefront is mobile-first.
Availability	Hosted availability target 99.9%; the storefront stays served from cache and the system degrades gracefully if a back-office component is down.
Security & privacy	Authentication (incl. an SSO option) and authorization checked on every action; PII & financing data protected in transit and at rest; secrets safeguarded; sensitive actions audited. Detailed obligations in Appendix B.
Scalability	Hundreds+ of tenants and tens of thousands of units & leads per tenant without degradation.
Portability / deployment	One product deploys hosted (multi-tenant) or self-host (single-tenant) by configuration/licence; no operator-only assumptions leak into tenant features.
Data & backups	Full per-tenant data export; regular backups with tested restore; tenant offboarding returns then erases the tenant's data.
Accessibility	Meets WCAG 2.1 AA for the storefront and internal tools; fully keyboard-navigable.
Observability	Logs, metrics and error tracking; per-tenant usage metering; uptime & latency visibility for the operator.
Auditability	Immutable history of status / price / discount / payment / document events with actor, timestamp and reason.
Internationalization	US-English / USD at launch; the data model avoids assumptions that would block later localization or multi-currency.

13 · Acceptance Criteria

The rebuild is "done" when the following end-to-end scenarios pass for a tenant, with figures reconciling across roles:

1. **Acquire→list.** Inventory Manager adds an incoming unit; Service completes intake & recon; Pricing sets list/floor; status flips to *available* and the unit appears on the storefront and syndication.
2. **Lead→quote.** A storefront "Request a quote" creates a Lead in the Lead Desk within seconds, routes to a salesperson, who builds a Quote tied to the unit.
3. **Negotiate→approve.** A below-floor offer requires Sales Manager approval, which is logged; the Deal advances to financing.
4. **Finance→title→deliver.** Customer applies for financing in the portal and sees status; Office tracks title to "in hand"; Dispatch schedules and tracks delivery to "delivered."
5. **Book.** Bookkeeper issues the invoice, records payment, and the sale appears in revenue/gross KPIs that match the Owner dashboard.
6. **Operate (hosted).** Super-Admin provisions a new tenant, sees it billed, and watches MRR/usage update.

14 · Glossary

Floor price	The lowest price a unit may be sold at without manager approval; protects margin.
Days on lot	Days since acquisition; drives aging & reprice decisions.
Recon	Reconditioning — the service work to make an acquired unit retail-ready.
Pipeline (value)	Sum of open-deal values; "weighted" multiplies each by win probability.
AR / AP	Accounts receivable (money owed to the dealer) / payable (money the dealer owes).
Syndication	Auto-publishing inventory to external listing channels.
Tenant	One dealership's isolated instance of the platform.
MRR / ARR	Monthly / annual recurring revenue (operator metric).

Appendix A · Data Dictionary

The logical data model — the entities the system manages, their key attributes and relationships. It is technology-neutral; the physical schema, storage engine and tenant-isolation mechanism are proposed in the Functional Specification Proposal. Conventions on every tenant-scoped entity:

- A stable unique identifier; created / updated timestamps; an optional soft-delete marker.
- A **tenant reference** on every business entity; isolation is enforced so no query path can cross tenants (self-host runs a single tenant).
- Money as fixed-precision decimal; flexible attributes as structured data; constrained value sets as enumerations (below).
- Every material mutation (status, price, discount, payment, signature) appends to an **immutable audit log**.

Table	Key attributes	Relationships
tenants	name, plan(enum), status(enum), domain, branding(jsonb), billing_ref, lots(jsonb)	root of isolation; platform-managed
users	name, email, password_hash, roles(text[]), lot_scope(text[]), active(bool), last_login	→ tenants; RBAC subject; uniq(tenant_id,email)
units (inventory — the spine)	stock_no, type, year, make, length, axles, capacity, condition, status(enum), lot_id, cost, list_price, floor_price, acquired_at, sold_at, views, lead_count, specs(jsonb)	uniq(tenant_id,stock_no); idx(tenant_id,status); → lots
unit_photos	unit_id, url, sort, is_cover(bool)	→ units (→ object storage)
leads	name, company, source, status(enum), value, phone, email, lost_reason	→ units (interest), → users (owner)
customers	name, company, phone, email, portal_user_id	buyer accounts; → users (portal)
deals	stage(enum), value, probability, financing_status	→ customers, → units, → users (salesperson)
quotes / **quote_lines**	quotes: total, valid_until, status · lines: kind(enum: price|prep|freight|tax|fee), label, amount	quotes → deals/units; lines → quotes
work_orders / **wo_tasks**	WO: type, status(enum), hours_est, hours_actual, parts_cost, opened_at, closed_at · task: label, done(bool), sort	WO → units, → users (tech); task → work_orders
invoices	kind(AR|AP), amount, status(enum), issued_at, due_at, note, vendor	→ customers / deals / units (nullable)
payments	amount, method, paid_at, reference	→ invoices; idempotent on reference
titles	status(enum), state, lien_holder, released_at	uniq(unit_id) → units
documents	kind, url, signed_at, signer, sign_request_id	→ deals / units; e-signature

deliveries	origin, destination, carrier, driver, status(enum), eta, freight_cost	→ deals, → units
activities (audit log)	entity_type, entity_id, actor_id, action, detail(jsonb), at	append-only; idx(tenant_id,entity_type,entity_id)
tasks / notifications	tasks: assignee_id, title, due_at, done, link(entity) · notif: user_id, kind, payload(jsonb), read_at	cross-cutting; → users

Enumerations

Enum	Values
unit.status	`incoming · recon · available · pending · sold`
lead.status	`new · working · quoted · won · lost`
deal.stage	`lead · quoted · negotiation · financing · delivery · won · lost`
work_order.status	`open · in_progress · waiting_parts · done`
invoice.status	`paid · due · overdue`
title.status	`in_hand · applied · pending · lien_release`
delivery.status	`scheduled · en_route · delivered`
tenant.plan / .status	`starter · growth · enterprise · license` / `active · trial · licensed · suspended`

Platform control plane (hosted mode only — operator data, outside tenant isolation)

Table	Key columns
subscriptions	tenant_id, plan, mrr, seats, started_at, status, billing_provider_ref
usage_metrics	tenant_id, period, units, leads, storefront_views, api_calls (for metering & billing)
support_tickets	tenant_id, subject, status, priority, opened_at
license_keys	key, owner, plan, seats, expires_at (validated by self-host installs)

Appendix B · Security, Privacy & Compliance

A trailer dealer that **arranges or extends financing** is a "financial institution" under the Gramm-Leach-Bliley Act — which pulls the FTC **Safeguards Rule** (16 CFR Part 314) onto every tenant, and onto TPOS as their service provider. These are **binding legal requirements**, not optional hardening. This appendix maps the regime to platform controls and a threat model.

> **Not legal advice.** Items marked COUNSEL turn on facts a lawyer must confirm (whether a given dealer's financing model triggers GLBA, FTC-vs-CFPB privacy applicability, per-state titling/lien law, and contractual liability allocation). Figures and citations are accurate as researched; verify against primary text before relying on them.

B.1 Regulatory surface

Regime	Trigger	Owner	TPOS role
GLBA **Safeguards Rule** — 16 CFR 314	Dealer arranges/extends financing → "financial institution"	Dealer (tenant)	§314.4(f) **service provider** — must safeguard by contract, support audits
GLBA **Privacy Rule** — 16 CFR 313 / Reg P	Same	Dealer	Generate/deliver privacy notices; track opt-outs COUNSEL
FTC Red Flags Rule — 16 CFR 681	Dealer = "creditor" with "covered accounts"	Dealer	Supply identity-theft detection signals + logging
Safeguards breach reporting — 16 CFR 314.5	≥ 500 consumers' *unencrypted* info	Dealer files FTC ≤ 30 days from discovery	Detect, count affected, start the clock, assemble the report
State breach-notification (50 states + DC)	Compromise of defined PII	Per affected resident's state	Fan out per-jurisdiction notices; store residency to query the set
ESIGN / UETA — 15 U.S.C. 7001	Any e-signed finance/sale document	Platform e-sign flow	Consent gate + tamper-evident, reproducible records
ECOA / Reg B retention — 12 CFR 1002.12	Credit applications	Dealer	Honor 25-month retention floor in disposal policy

Requirement — the #1 risk is cross-tenant data disclosure. Tenant context must be derived server-side (never from a client-supplied identifier) and isolation enforced *in depth* — at the authorization layer and again at the data layer — so no request can read or write another tenant's data, even with a code bug. Provable by an automated negative test. The concrete mechanism is proposed in the Functional Specification Proposal.

B.2 Safeguards Rule control map (16 CFR 314.4)

Each required element of the written information-security program, mapped to the platform control that satisfies it. The §314.6 partial exemption (< 5,000 consumers) relaxes four sub-elements for small dealers; TPOS implements the full set regardless.

§314.4 element	TPOS control
(a) Qualified Individual	Named security owner per tenant; TPOS may serve as the QI by contract for hosted tenants
(b) Written risk assessment	Tenant-facing risk-assessment template + periodic review prompt
(c)(1) Access controls	Least-privilege RBAC across the 12 roles; field-level masking of PII / title / payment data
(c)(2) Data inventory	Catalog of systems/fields holding customer info (this spec + data dictionary)
(c)(3) **Encryption** in transit & at rest	TLS everywhere; encrypted volumes; column-level encryption / tokenization for tokens & PII
(c)(4) Secure development	Secure SDLC; dependency & secret scanning in CI
(c)(5) **MFA**	MFA required on every login (mandatory for admin / title / payment roles)
(c)(6) **Secure disposal**	Retention engine: default purge of unused PII ≤ 2 years, overridden by legal-hold floors (ECOA 25 mo., title/finance records)
(c)(7) Change management	Reviewed, audited deploy pipeline; isolation-policy presence checked in CI
(c)(8) **Monitoring / logging**	Immutable, append-only audit log of who-did-what-to-which-record-when
(d) Testing	Annual penetration test + vulnerability assessment ≥ every 6 months (absent continuous monitoring)
(e) Training	Security-awareness training; qualified security staff
(f) **Service-provider oversight**	The clause that binds TPOS: contractual security commitment, right to assess, breach-cost allocation
(g) Keep current	Re-evaluate program on testing results, material change, new threats
(h) Written incident-response plan	Documented IRP (roles, comms, remediation, post-mortem) wired to B.5
(i) Annual board report	QI's written annual report — exportable from the platform

Liability. Primary duty is the dealer's, and using a provider does not relieve it (§314.4(f)). But the FTC *has* acted directly against auto-dealer software providers (2019 settlement), so TPOS carries

real exposure and allocates it by contract (MSA/DPA). COUNSEL

B.3 Privacy, e-signature & breach response

- **Privacy Rule.** The dealer issues the notice + opt-out; TPOS generates/delivers notices and tracks opt-outs. The §313.13 **service-provider exception** (a contractual use-restriction) is what lets the dealer share customer NPI with TPOS without an opt-out — so that clause must be in the contract. *Note: privacy rulemaking splits FTC (vehicle dealers) vs CFPB Reg P (others) — cite FTC 16 CFR 313 for dealers.* COUNSEL
- **E-signature (ESIGN/UETA).** Capture intent-to-sign; run the consumer-consent gate (affirmative consent + demonstrated ability to access the electronic form + the required pre-consent disclosures + a withdrawal mechanism); store tamper-evident, reproducible records (signer identity, timestamp, IP, document hash). **Title documents are carved out** — UETA §3 and many state codes exclude documents of title; treat titling as per-DMV, not generic e-sign.
- **Breach response.** Instrument detection to count affected consumers and whether data was encrypted; auto-start the **≤ 30-day FTC clock** (16 CFR 314.5) and fan out **state notifications by the affected resident's state**. Capture residency in the data model so the per-state affected set is queryable — the same per-jurisdiction pattern as titling.

B.4 Threat model — STRIDE × asset

Highest-priority cells shaded conceptually below; **Information disclosure × tenant data** (cross-tenant leak) is the single dominant risk.

Asset \ STRIDE	Spoofing	Tampering	Repudiation	Info disclosure	DoS	Elevation
Tenant business data	—	Server-side write checks	Audit log	**Enforced isolation ◆**	Rate limit	Least-privilege data access
Staff sessions	**Hardened sessions, MFA ◆**	Signed / rotated	Audit log	Not script-readable	Throttle login	Re-auth on privilege change
Portal / API tokens	Short-lived, scoped	Integrity-verified	Token id in log	Never logged	Per-token limit	Scope = role
Payment instruments	—	**Tokenized ◆**	Audit log	Encrypted	—	Role-masked
Titles / PII	—	Integrity-checked	Audit log	Encrypted + masked	—	Field-level authz
Uploaded files	—	Content-type verified	Audit log	Private storage	Size limit	Re-encoded
Public storefront	—	Read-only view	—	Published view only	**Edge cache ◆**	—
Audit log itself	—	**Append-only ◆**	n/a	Restricted read	—	Separate write path

B.5 Controls checklist (required outcomes)

Stated as outcomes the build must achieve; the concrete mechanisms (isolation technique, password hashing, session & token handling, connection pooling) are proposed in the Functional Specification Proposal.

Tenant isolation — the #1 risk

- Isolation enforced at the **data layer**, not only in application code, so a forgotten check cannot leak data.
- The application's normal data access cannot bypass the isolation boundary.
- Writes are constrained to the acting tenant (no insert / update into another tenant).
- Tenant context is derived from the authenticated session/token **server-side** — never from a client-supplied identifier (defends OWASP API #1, broken object-level authorization).
- A **CI negative test** proves tenant A cannot read, update, delete or insert-as tenant B — at both API and data layers; any leak fails the build.

Authentication & authorization

- Hardened sessions (theft-resistant, rotated on login, idle + absolute timeouts, server-side invalidation).
- Passwords stored with a strong, salted, memory-hard hash; **MFA** available and required for sensitive roles.
- Login throttling / lockout; safe password reset (single-use, time-limited, no account enumeration).
- API / portal tokens short-lived, scoped to the role, and fully validated.
- Cross-site request forgery defended for browser sessions.
- Role-based authorization with field-level masking of PII / title / payment data.

Cross-cutting

- Secrets held in a managed secret store, never in source control; keys rotated.
- Encryption in transit and at rest; payment instruments and sensitive PII additionally tokenized / encrypted.
- Immutable, append-only audit log (the non-repudiation control).
- Rate limiting per IP / token / tenant on authentication, API and upload.
- Server-side input validation; no injection-prone query construction.
- Secure file upload: real content-type verification, randomized names, private storage, malware scan, image re-encode.
- Server-side URL fetches restricted to prevent server-side request forgery.

B.6 Data-model requirements

To satisfy the above, the data model must additionally carry: an **immutable audit log** (append-only, tenant-scoped); **e-signature consent records** (consent + document hash + signer / timestamp / address); **customer residency** (to drive per-state breach notice); and a **retention policy** (per-record-type disposal floors versus the 2-year default). Payment instruments store **only a token + last4 + brand**, never full numbers.

B.7 Primary sources

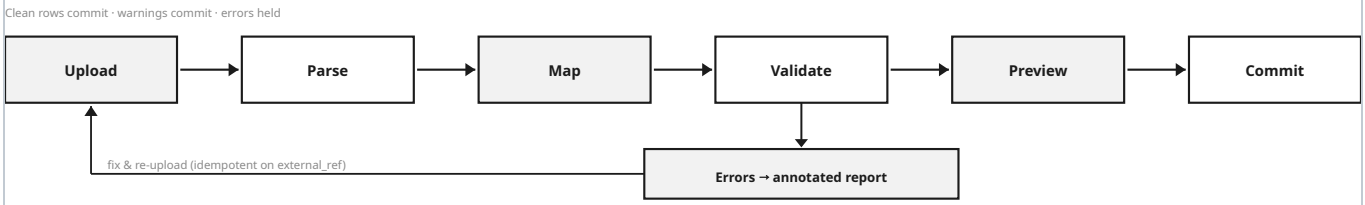
- FTC Safeguards Rule — 16 CFR 314.3–314.6 (eCFR; Cornell LII 314.4); FTC *"Safeguards Rule: What Your Business Needs to Know"* and *Automobile Dealers Safeguards FAQs*.
- Breach reporting — 16 CFR 314.5; FTC *"Safeguards Rule notification requirement now in effect"* (2024).
- Privacy Rule — 16 CFR Part 313 (esp. 313.13 service-provider exception); FTC *Privacy Rule & Auto Dealers FAQs*. Red Flags — 16 CFR 681.1 + App. A.
- ESIGN — 15 U.S.C. 7001(a)(c)(d), 7006; UETA §§2,3,12 (Uniform Law Commission).
- State breach laws — NCSL *Security Breach Notification Laws*. Retention — 12 CFR 1002.12 (Reg B).
- Threat model — OWASP API Security Top 10 (API1:2023 BOLA), OWASP ASVS Cheat Sheets (Session, Password Storage, CSRF, File Upload); PostgreSQL RLS docs; Supabase RLS guidance; Microsoft STRIDE.

Appendix C · Onboarding & Data Import

How a dealership goes from signup to live — and imports its existing book of inventory, customers and deals. Sales/CRM products have the **slowest time-to-first-value precisely because of import friction**, and B2B median activation is only ~37.5%; past **14 days** the great majority of signups have already churned. The import wizard *is* the onboarding bottleneck, and the highest-leverage thing to build well.

C.1 Tenant provisioning — one automated path, branches on plan tier

#	Step	Detail
1	Account + tenant_id	Self-serve and assisted requests enter the same registration service
2	Subdomain + branding	Logo, colors; custom domain is a later tier
3	First admin in central IdP	tenant_id / tier / roles stamped as claims
4	IaC provisioning	Schema, default roles — scripted, zero hand-config
5	Defaults	Lots/locations, deal stages, unit statuses, tax/fee defaults
6	Sample data	Seed explorable demo data the dealer can wipe before real import
7	Team invites	Role-based invitations
8	Billing — **async**	Non-blocking; dealer reaches a working dashboard before billing finishes
9	Land on import wizard	First in-app action; **activation event** = “first 10 units live + first deal created”



The import pipeline. Clean rows commit; rows with *warnings* still commit; rows with *errors* are held and returned as an annotated report for the fix-and-reupload loop. Every row is keyed on `external_ref` so re-uploading the same file upserts rather than duplicating.

C.2 Import pipeline specification

Column mapping

- Fuzzy **auto-map** to canonical fields (target ~95% auto-matched), with manual remap.
- Show, per canonical field, an inline **description + sample value**; allow split/merge (one “Customer Name” → first/last).

- **Persist the mapping profile** keyed to the dealer's source DMS so repeat uploads are seamless.

Validation — three layers

- **Per-column:** type, required, enum. **Normalize** messy legacy values ("sold", "SOLD", "S" → canonical `unit_status` / `deal_stage`) via a mapping table; infer date formats (MM/DD vs DD/MM).
- **Referential:** import in dependency order (units + customers *before* deals); reject a deal whose unit/customer key doesn't resolve.
- **De-duplication:** units by VIN / serial / stock_no, customers by email / phone — **surface collisions, never silently merge**.

Preview, commit, errors, re-runs

- **Errors vs warnings** split — the partial-success mechanism (warnings commit; errors hold).
- Row-level inline errors with a "show only problem rows" filter, in-app fix, undo; **downloadable annotated error file** for re-upload.
- Failed rows → staging queue, never abort the whole file.
- **Idempotent** re-runs: every row keyed on a stable `external_ref`; the bulk API accepts an `Idempotency-Key`.
- Robust parsing: BOM/encoding detection, Excel-CSV quirks, embedded commas/newlines; async background worker with an `import_id`; chunk 50–500 rows (MVP may cap row count).

C.3 Migration strategy

- Split **static/master** (units, customers — migrate days ahead) from **dynamic/transactional** (open deals/WIP — migrate at cutover).
- Advise dealers to **"drain the line"** (~2 weeks) so open WIP is minimal at go-live.
- **Migrate active data only; archive closed history as CSV** (not live records).
- **Reconciliation screen** before go-live: source-vs-target counts per entity + a sampled spot-check (e.g. 10 units, 5 customers).
- **Rollback triggers:** a hard-stop time and a **> 0.5% record-count variance auto-revert**; keep the old DMS read-accessible through cutover.
- One-time migration is the default; live two-way sync with a legacy DMS is out of scope. Offer a no-commit **dry-run**.

C.4 Import templates & bulk endpoint

Ship one downloadable template per entity, **generated from the canonical schema so they never drift**, plus a `/api/v1/bulk/{entity}` upsert endpoint (external_ref-keyed, idempotent) mirroring the wizard. Suggested columns (reconcile against Appendix A):

Entity	Template columns
units	`external_ref, vin_serial, stock_no, year, make, model, type, length, axles, capacity, mileage_hours, condition, cost, recon_cost, transport_cost, list_price, floor_price, status, lot, acquired_at, photos_ref`

customers	`external_ref, first_name, last_name, company, email, phone, address1, address2, city, state, zip, notes`
leads	`external_ref, customer_external_ref, source, status, interest_unit_ref, assigned_to, created_at, notes`
deals	`external_ref, unit_external_ref, customer_external_ref, stage, sale_price, fees, taxes, down_payment, financing_terms, salesperson, opened_at`

Schema delta. Add an `external_ref` column to every importable entity (absent today) so import is idempotent and legacy ids are preserved.

Primary sources

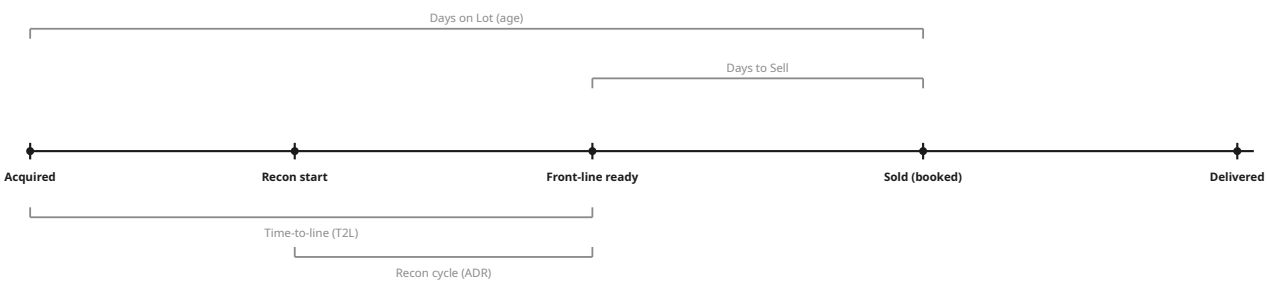
- AWS Well-Architected SaaS Lens — *Tenant Onboarding Best Practices*; multi-tenant provisioning write-ups (IaC, async billing).
- Time-to-value data — DigitalApplied *SaaS TTV Framework* (median ~1.5-day TTFV; >14-day "lost" cohort; 37.5% B2B activation).
- Import UX — OneSchema (*Building a CSV Uploader*, *Advanced Features*), Flatfile (fuzzy auto-match), Domo ETL (staging dedup), Salesforce Bulk API 2.0 (upsert-by-external-id), idempotency-key guidance.
- DMS migration — LotPulse *Switch Your DMS*, P2-Innovate *static-vs-dynamic cutover*, Concentrus *cutover plan* (reconciliation, 0.5% rollback threshold).

Appendix D · Derived-Field Formulas

Unambiguous formula definitions so two independent rebuilds compute identical numbers. The single biggest source of divergence is the **age clock**; it is resolved by persisting separate date stamps per unit and naming which clock each metric uses.

D.0 Conventions (state once, apply everywhere)

- One **day-count convention** (inclusive vs exclusive of endpoints), applied uniformly to age, days-to-sell, recon, DSO and aging buckets.
- **Every "%" field declares its denominator** (price vs cost vs market).
- One global **"sold" trigger** — booked / funded / **delivered**; default **delivered** (ASC 606). It propagates to units-sold, velocity, conversion and revenue recognition.
- Persist five date clocks per unit: `acquired_at`, `recon_started_at`, `frontline_ready_at`, `sold_at` (booked), `delivered_at`.



The five date stamps a unit must carry, and the spans derived from them. Most aging/turn ambiguity disappears once these are stored separately rather than collapsed into one "date".

D.1 Inventory & aging

Metric	Formula	Notes / variants
Days on Lot (age)	`(sold_at | today) − acquired_at`	Floor-plan/aging clock; from acquisition
Days to Sell	`sold_at − frontline_ready_at`	Retail speed; excludes recon — store **both**
Aging buckets	assign `age_days` to `[lo, hi)`	Default 0–30/31–60/61–90/90+ — **configurable**
Inventory turn (cost)	`COGS / avg_inventory_value`	Annualize × (365 / days_in_period)
Inventory turn (unit)	`units_sold / avg_units_in_stock`	Non-equivalent to cost turn — label which is shown

Total cost basis	`acquisition + recon + transport + capitalizable_fees`	"All-in"; provisional until recon RO closes
Recon cycle (ADR)	`frontline_ready_at − recon_started_at`	vs Time-to-line `frontline_ready_at − acquired_at`

D.2 Pricing & profit

Metric	Formula	Notes / variants
Front-end gross	`sale_price − total_cost_basis − pack`	Excludes F&I, holdback, incentives (configurable)
Back-end gross (F&I)	`finance_reserve + warranty + GAP + other_FI`	Each = price_to_customer - cost_to_dealer
Total gross / margin %	`(front + back); total_gross / sale_price × 100`	Margin is on **selling price**
Margin vs markup	`margin% = (p−c)/p; markup% = (p−c)/c`	Not interchangeable — declare denominator
Holding cost / day	`(amount_financed × rate)/360` or fully-loaded NADA/Cox	360 vs 365 configurable; ~$40–50/day used-unit benchmark
Age-adjusted gross	`front_end_gross − holding_per_day × age_days`	Shows margin erosion as a unit ages
Price/Cost-to-market	`price (or basis) / avg_market_like × 100`	Needs external comp feed — flag data-dependent

D.3 Sales & deal

Metric	Formula	Notes / variants
Commission	**rules engine**, not a constant	flat / %-of-gross-after-pack / mini-floor / tiered + spiffs — all configurable
Conversion (by stage)	`stage_outcomes / stage_inputs × 100`	Define lead dedup + attribution window; unwind reverts the count
Avg sale price / velocity	`Σ sale_price / units; units / days_in_period`	Exclude voided/unwound; "sold" per the global trigger
Sales tax & fees	**jurisdiction table**	Never hard-coded; base/rate/doc-fee vary by locale

D.4 Money & AR

Metric	Formula	Notes / variants

DSO	`(avg_AR / net_credit_sales) × days_in_period`	Pair with AR aging; period/denominator configurable
AR aging	bucket by `today − invoice_date`	Contracts-in-transit = its own AR sub-ledger
Balance due	`total_price − deposits − trade − rebates`	Deposit is a **liability** until delivery
Revenue recognition	at **delivery** (ASC 606, point-in-time)	"Sale date" ≠ "recognition date"; voided delivery reverses revenue + gross + commission

D.5 "Configurable" register

Every legitimately-variable choice — expose as a tenant setting, not a constant: aging-bucket boundaries · turn basis (cost vs unit) & averaging method · cost-basis inclusions · holding rate + 360/365 day-basis · all commission parameters (pack, rate, mini, tiers, commissionable base) · conversion attribution window & dedup · tax/fee jurisdiction tables · DSO period length & denominator · the global "sold" trigger.

Schema delta. `units` today has only `acquired_at` / `sold_at` and a single `cost`; add `recon_started_at`, `frontline_ready_at`, `delivered_at` and the cost components `recon_cost` / `transport_cost`. `deals` needs a front/back-gross + fees/tax/pack breakdown beyond the single `value`.

Primary sources

- Inventory/turn/aging — NADA *Analyze Your Inventory* & Slide Guide, acvmax, NetSuite, Wall Street Prep (turnover, sell-through), Lightspeed.
- Recon/T2L — Cartuul, AutoSuccess (ADR). Profit — Nimble (front/back gross), Edmunds, AccountingTools / Consero (margin vs markup), Cox Automotive / NextGear (floor-plan & holding cost), vAuto (PTM / market-days-supply).
- Commission & conversion — myCommissionCalc, Demand Local, Foureyes, evox. AR & rev-rec — Wall Street Prep / CFI / AccountingTools (DSO), Versapay, RevenueHub & Deloitte DART (ASC 606 point-in-time), Wipfli.

Appendix E · Notification & Document Catalog

Every system-generated message and legal document: its trigger, channel, recipient and template variables. **Transactional** messages (tied to a transaction the recipient is party to) are exempt from marketing opt-out; **marketing** messages intersect the GLBA Privacy Rule opt-out (Appendix B.3) and CAN-SPAM/TCPA.

Event	Channel	Recipient	Template variables	Type
Lead received	Email + in-app	Assigned salesperson, lead desk	lead_name, source, interest_unit, contact	Transactional
Quote sent	Email (+ portal)	Customer	unit, price, prep, freight, tax, total, valid_until, accept_link	Transactional
Financing decision	Email + portal	Customer, salesperson	decision, terms, next_step	Transactional
Deposit / payment received	Email	Customer, bookkeeper	amount, method (last4), invoice_no, balance_due	Transactional
Work-order status	In-app	Service mgr, inventory mgr	unit, wo_status, hours, parts	Transactional
Title cleared / lien released	Email + in-app	Office, customer	unit, title_status, state	Transactional
Delivery scheduled / en-route / delivered	SMS + email + portal	Customer, dispatch	unit, eta, carrier, tracking	Transactional
Invoice due / overdue	Email	Customer, bookkeeper	invoice_no, amount, due_at, days_overdue, pay_link	Transactional
Marketing / re-engagement	Email	Customer (opted-in)	saved_units, new_matches	**Marketing** — opt-out applies

E.1 Compliance documents

- **Privacy notice** (GLBA/Reg P) — generated, delivered, opt-out tracked (E.3).
- **E-sign consent record** — consent + document hash + signer/timestamp/IP (E.3).
- **Breach notice** — FTC report (≤30 days, ≥500 consumers) + per-state consumer notices (E.1/E.5).
- **Adverse-action / Red Flags** notices where financing is declined or identity flags fire (E.1).

Appendix F · Accounting-System Export

The bookkeeper must be able to **manually export financial transactions to the dealer's accounting system** on demand — **QuickBooks first** (both Online and Desktop), with other systems supported later **without a rewrite**.

F.1 Requirements

- Manual, **on-demand export** of financial transactions — invoices, payments and summary journal entries — to the dealer's accounting system.
- Must support **QuickBooks first** (both QuickBooks Online and QuickBooks Desktop), and be **extensible to other systems** (Xero, Sage, NetSuite, …) without re-engineering the export core.
- A **one-time chart-of-accounts mapping** per dealer (the system's revenue / COGS / AR / sales-tax / fees / deposits → the dealer's own accounts).
- **No duplicate postings** on re-export — each exported batch is idempotent and marked as exported.
- The baseline export must work **without granting the system third-party access it cannot govern** and without depending on an external approval gate.

The format choices (file vs API), the QuickBooks-specific constraints, and the canonical-model + per-target-adapter design that keeps "other systems later" cheap are analyzed and recommended in the **Functional Specification Proposal**.